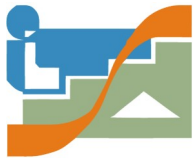


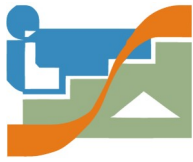
UNITAT 05

NOTIFICACIÓ d'IC

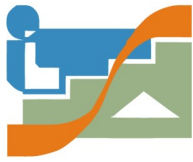




- **Compliance**
- **Desenvolupar procediments d'actuació per la notificació d'incidents**
- **Notificació interna d'incidents**
- **Notificació d'incidents a qui corresponga**



- **Compliance**
- Desenvolupar procediments d'actuació per la notificació d'incidents
- Notificació interna d'incidents
- Notificació d'incidents a qui corresponga

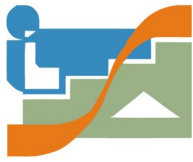


Compliance

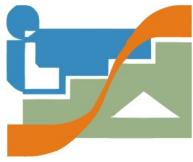
El Compliance és un conjunt de procediments i bones pràctiques adoptats per les organitzacions per a identificar i classificar els riscos operatius i legals als quals s'enfronten i establir mecanismes interns de prevenció, gestió, control i reacció enfront d'aquests.

Resumint: Sistema de prevenció del delictes i compliment normatiu

<https://www.ealde.es/tipos-compliance/>



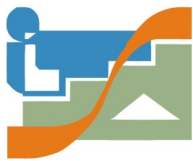
- Compliance
- Desenvolupar procediments d'actuació per la notificació d'incidents
- Notificació interna d'incidents
- Notificació d'incidents a qui corresponga



Desenvolupar procediments d'actuació per la notificació d'incidents

En paraules del CCN-CERT, “La notificació d'incidents, és clau per a la seguretat nacional”

- **Crear canals de comunicació (interna a la organització)**
- **Securitzar i confiabilitzar dits canals**
- **Promocionar i informar a tots el possibles destinataris**
- **Formar i preparar als usuaris actius dels canals**
- **Fer proves**



Desenvolupar procediments d'actuació per la notificació d'incidents

Els incidents s'associaran a algun dels següents nivells d'impacte: **CRÍTIC, MOLT ALT, ALT, MITJÀ, BAIX o SENSE IMPACTE**, i a algun dels següents nivells de perillositat: **CRÍTIC, MOLT ALT, ALT, MITJÀ, BAIX o SENSE IMPACTE**.

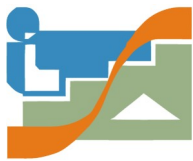


Serà obligatòria la notificació de tots aquells que es categoritzen amb un nivell **CRÍTIC, MOLT ALT O ALT**, per a tots aquells subjectes obligats als quals els siga aplicable normativa específica

Un exemple

<https://www.muyseguridad.net/2022/02/09/cinco-pasos-filtracion-datos/>

Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad.
https://www.boe.es/diario_boe/txt.php?id=BOE-A-2022-7191



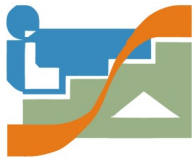
Desenvolupar procediments d'actuació per la notificació d'incidents

Els criteris emprats per a la determinació del nivell d'impacte associat a un ciberincident atenen els següents paràmetres:

- **Impacte en la Seguretat Nacional o en la Seguretat Ciutadana.**
- **Efectes en la prestació d'un servei essencial o en una infraestructura crítica.**
- **Tipologia de la informació o sistemes afectats.**
- **Grau d'afectació a les instal·lacions de l'organització.**
- **Possible interrupció en la prestació del servei normal de l'organització.**
- **Temps i costos propis i aliens fins a la recuperació del normal funcionament de les instal·lacions.**
- **Pèrdues econòmiques.**
- **Extensió geogràfica afectada.**
- **Danys reputacionals associats**

CCN STIC 817 (Gestión de incidentes en el ENS) Guia de seguridad de las TIC

<https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/988-ccn-s-tic-817-gestion-de-ciberincidentes/file.html>



Desenvolupar procediments d'actuació per la notificació d'incidents

Qui està obligat a reportar ?

- ÀMBIT DEL SECTOR PÚBLIC
- ÀMBIT DEL SECTOR PRIVAT

On reportar ?

- CCN-Cert
- INCIBE

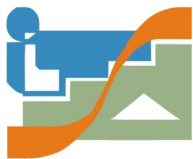
Com reportar ?

- Finestreta única

Perquè notificar ?

- Obligació
- Millora del sistema
- Reputació

Quan notificar ?



Desenvolupar procediments d'actuació per la notificació d'incidents

On reportar ?

- ccn-cert



Ferramenta REYES : És una solució desenvolupada pel CCN-CERT per a agilitzar la labor d'anàlisi de ciberincidents i compartir informació de ciberamenaces

Ferramenta LUCIA (Listado Unificado de Coordinación de Incidentes y Amenazas) para aquellas entidades del ámbito del Esquema Nacional de Seguridad

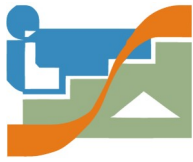
Email: (incidentes@ccn-cert.cni.es) Per fer una descripció més detallada de l'incident.



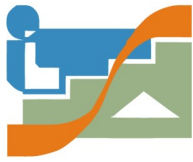
Repositorio común y estructurado de
amenazas y código dañino.



Herramienta de ticketing para la gestión
de incidentes de seguridad.



- **Compliance**
- **Desenvolupar procediments d'actuació per la notificació d'incidents**
- **Notificació interna d'incidents**
- **Notificació d'incidents a qui corresponga**

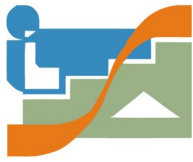


Notificació interna d'incidents

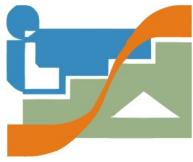
Pla d'emergència. **Immediatament.**

Resta de personal afectat. Personal intern, proveïdors i clients

(Considerar canals i protocols segurs de comunicació interna per evitar atacs)



- **Compliance**
- **Desenvolupar procediments d'actuació per la notificació d'incidents**
- **Notificació interna d'incidents**
- **Notificació d'incidents a qui corresponga**

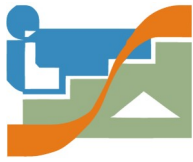


Notificació d'incidents a qui corresponga

- **A tots els treballadors**
- **A totes les persones externes que treballen amb l'empresa**
- **A totes les persones, les dades de les quals, s'han vist compromeses**
- **Mantindre línies de comunicació obertes**
- **Evitar tecnicismes**
- **Transparència**

Evitar danys reputacionals

- **Mitjans de comunicació**
- **Xarxes socials, compte de l'organització.**

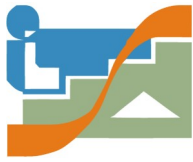


Notificació d'incidents a qui corresponga

bretxa de seguretat

- RGPD

- Totes aquelles fallades de seguretat que ocasionen la destrucció, pèrdua o alteració accidental o il·lícita de dades personals transmeses, conservats o tractats d'una altra forma, o la comunicació o accés no autoritzats a aquestes dades
- Primera notificació en les primeres 72 hores
- on? en <https://sedeagpd.gob.es/sede-electronica-web>



Podem vore més informació en la Guia per a la gestió i notificació de bretxes de seguretat

AGENCIA
ESPAÑOLA DE
PROTECCIÓN
DE DATOS



<https://www.aepd.es/sites/default/files/2019-09/guia-brechas-seguridad.pdf>